MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 021 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

GOVERNANCE · CMMC DOCUMENTATION

How Many Documents Does CMMC Level 2 Actually Require?

NIST 800-171 names 110 requirements but no document count. Scoping a CMMC Level 2 documentation set is a governance decision - here is what the 110 imply.

BY **MAXINE** READING TIME · 6 MIN CMMC · NIST-800-171 · COMPLIANCE · GOVERNANCE · DOCUMENTATION

Ask five vendors how many documents CMMC Level 2 requires and you will get five confident numbers, every one of them wrong in the same way: NIST SP 800-171 does not name one. The framework states 110 security requirements, assessed through 320 objectives, and nowhere does it prescribe a count of policies, plans, or procedures. The size and shape of your documentation set is a decision you make - a governance decision about scope - and the assessor does not merely read the documents. The assessor assesses the decision.

That silence in the regulation produces two failure modes, and the better-funded one is worse. The first is the stationery response: buy the biggest binder on the market, two hundred templates deep, and mistake weight for readiness. It feels like safety and it is actually a liability register. Every controlled document you publish is a commitment that your organization does the thing the document says, and an assessor's method is to sample practice against paper. A procedure nobody follows is not neutral shelf-filler; it is a finding you wrote yourself, in advance, in your own voice. The arithmetic compounds quietly: every document needs an owner, an approver, and a review cadence, and two hundred documents on an annual cycle is a review due roughly every working day of the year. A thirty-person machine shop did not budget for that hidden employee, so the reviews lapse, and now the set is both oversized and stale.

The opposite failure forfeits points rather than accruing them. "We have policies" is the sentence assessors hear most and credit least, because a policy answers only the top layer of what the 320 objectives ask. The objectives want to know whether things are *defined*, *specified*, *identified*, and then whether the defined thing actually operates - and those answers live in procedures, plans, agreements, and above all in the records that a working procedure throws off. A policy stating that access is restricted to authorized users cannot produce the user access register that shows who was authorized in March and who signed for it. Intent without machinery scores as absence.

Every controlled document you publish is a promise an assessor will check you kept.

Read the 110 as a bill of materials, not a reading list

The way out of both failures is to derive the set from the requirements instead of buying it by the pound, and MacTech's own program is a usable worked example. The canonical set MacTech maintains for its CUI enclave runs to 64 controlled documents, mapped to all 110 requirements and all 320 assessment objectives. The anatomy is the instructive part: 18 policies, 29 procedures, 6 system-scope descriptions, 4 plans (incident response and security assessment among them), 4 signed agreements, 2 technical standards, and one system security plan.

Notice what dominates. Procedures outnumber policies twenty-nine to eighteen, because that is roughly the ratio the requirements themselves imply: for every "we shall" the framework wants at least one "here is how, step by step, and here is the record it leaves." The smaller families earn their places the same way. System descriptions are scoping documents - boundary, data flows, what is inside and what is out - and they exist because an assessor's first hour is

FIELD COPY
ISSUE Nº 021
CMMC

64

CONTROLLED DOCUMENTS IN MACTECH'S CANONICAL SET, COVERING ALL 110 REQUIREMENTS

29 : 18

PROCEDURES TO POLICIES - THE SET'S CENTER OF GRAVITY IS THE HOW, NOT THE SHALL

1,595

OF 1,595 INTAKE ANSWERS LANDED EXACTLY WHERE THE TRACE SAID THEY WOULD

◆ THE DOCUMENTS A FORM CANNOT WRITE

MacTech's intake workbook deliberately excludes an expert-led tier, the SSP first among them. A system security plan describes one specific system as it actually runs; a version derived from form answers would be the generic SSP an assessor learns to distrust by page two.

spent establishing what the words "the system" mean. Agreements exist because some obligations bind people and outside parties, and a policy cannot sign anything. None of these counts is a magic number; all of them are outputs of reading the requirements as a bill of materials.

The mapping is what makes the set assessable rather than merely large. In MacTech's requirement map, each of the 110 carries a primary document, its supporting documents, the record it must generate, and the specific evidence an assessor is expected to request. An access-control requirement lands on the access policy, executes through provisioning procedures, binds each user through a signed agreement, and proves itself in the register those procedures maintain. Scope, in other words, is not the question "which documents do we own." It is the question "which requirement does each document carry, and what record shows it working."

Inheritance bends the answer further, and in the buyer's favor. In the enclave-based delivery MacTech ships as its Vault Edition, a shared-responsibility matrix splits the same 110 requirements three ways: 64 carried by the provider, 44 shared, and exactly 2 resting solely on the customer. A documentation set that ignores that split documents things its author does not operate and cannot evidence - the same overstatement, in paper form, that we priced in the enclave-versus-whole-network decision. The Level 2 practice page covers where that boundary conversation starts.

The lifecycle of the set is itself on the exam

Here is the part the stationery vendors never mention: the governance of your documents is assessed alongside their contents. An assessor will ask who owns this procedure, who had authority to approve it, when it was last reviewed, and what happened to the revision it replaced - and "the consultant who wrote it left in 2024" fails all four at once. A document set is not a deliverable. It is an operated system with a lifecycle, and the lifecycle needs the same evidence discipline as any control.

MacTech runs its own set the way it advises customers to. All 64 documents carry a named owner, a named approval authority, and an annual review cadence, and the set is released through the company's quality management system with e-signature approvals, controlled release, and supersession that retires the prior revision the moment its replacement takes effect. That is the document-as-you-build discipline this newsletter keeps returning to, applied to the paper itself: the company's compliance documentation is governed by the same QMS machinery it sells, which is why it can show a customer the release record rather than describe one.

The productized version of that set - a Standalone Template Kit, and the Vault Edition that adds the shared-responsibility matrix and pre-filled architecture facts - ships with SHA-256 checksums, so a customer can verify that the set received is the set released. Filling it is governed too. The intake is a structured workbook of roughly 400 fields, and every answer is traced to its exact landing spots across the document set; a recent audit walked that trace end to end and found 1,595 of 1,595 placements landed exactly where the map said they would. A template kit without that traceability is mail-merge and hope.

And one tier of the set is deliberately not templated at all. Expert-led documents, the SSP first among them, are excluded from the workbook because they cannot be derived from a form: an SSP is an account of one specific system as it actually runs, and the assessor reads it like one. A vendor whose kit claims to generate everything is telling you which documents they have never had assessed.

So the honest answer to the opening question is a shape, not a number: as many documents as your boundary and your inheritance actually imply, and no more than you can own, approve, review, and supersede on schedule. Sixty-four is MacTech's answer for MacTech's boundary; yours might be forty-five or eighty. What cannot vary is that every one of them traces to a requirement, generates a record, and carries a living lifecycle. The regulation never asked you for a count. It asked you for a system - and the count is just what a working system leaves behind. ◆